

บทที่ 1

บทนำ

1.1 ความสำคัญและที่มาของโครงการ

ในปัจจุบันยังมีความรู้เกี่ยวกับเว็บเทคโนโลยีน้อยมาก ซึ่งคนที่ไม่มีความรู้มักตกเป็นเหยื่อการโจมตีจากผู้ไม่หวังดีซึ่งมีความรู้ความสามารถมากกว่า สำหรับการบรรเทาและป้องกันอันตรายที่อาจจะเกิดขึ้นนั้น จำเป็นต้องให้ความรู้แก่บุคคลทั่วไป โดยเฉพาะอย่างยิ่งบุคลากรในองค์กรต่างๆ โดยให้ความรู้เพื่อที่จะป้องกันตัวเองได้ในระดับหนึ่ง ดีกว่าให้เผชิญปัญหาต่างๆด้วยตนเอง ด้วยแนวคิดนี้ทำให้ทางผู้พัฒนาโครงการได้จัดทำเว็บเพื่อให้ความรู้เกี่ยวกับการเจาะระบบและการป้องกันการโจมตีในเว็บเทคโนโลยี โดยเฉพาะวิธีที่เป็นที่นิยม ทางผู้พัฒนาโครงการได้จัดทำชุดทดลอง เพื่อให้ผู้ใช้งานได้การทดลองการทำการเจาะระบบโดยใช้วิธีการต่างๆ เพื่อเรียนรู้การโจมตีและสามารถป้องกันได้ด้วย โดยไม่ต้องไปทดลองตามเว็บอื่นๆ ให้เกิดความเสียหายต่อเว็บนั้นๆ ซึ่งการป้องกันนั้นเป็นสิ่งที่ทางโครงการได้เน้นเป็นหลัก

โครงการนี้มุ่งเน้นที่จะให้ความรู้กับคนในองค์กร เพื่อป้องกันตัวเองในระดับเบื้องต้นจากผู้ไม่หวังดี รู้ว่าผู้ที่ไม่หวังดีนั้นสามารถจะทำอะไรกับระบบได้บ้างและต้องการให้ผู้ใช้งานได้ทำการทดลองด้วยวิธีการจำลองสถานการณ์และทราบการป้องกันว่าสามารถทำได้อย่างไร โดยในโครงการนี้มีหัวข้อในการเจาะระบบผ่านเว็บหัวข้อหลักๆ คือ SQL Injection, Hidden Manipulation, Java Injection, Cross Site Script (XSS), Query Poisoning, Session Hijacking, Parameter Tempering, Application Buffer Overflows

1.2 วัตถุประสงค์ของโครงการ

ปริญญานิพนธ์ฉบับนี้มุ่งหวังเพื่อศึกษาการถึงวิธีการเจาะระบบผ่านเว็บที่ได้รับความนิยมในปัจจุบันคือ SQL Injection, Hidden Manipulation, Java Injection, Cross Site Script (XSS), Query Poisoning, Session Hijacking, Parameter Tempering และ Application Buffer Overflows เพื่อให้ความรู้เกี่ยวกับปัญหาความปลอดภัยในเว็บเทคโนโลยีและสร้างเว็บไซต์ที่ให้ความรู้ในหัวข้อดังที่กล่าวไปข้างต้น อีกทั้งยังสามารถทำการทดลองและทำการป้องกันได้ภายในเว็บไซต์

1.3 ขอบเขตของโครงการ

ในปฏิญานิพนธ์ฉบับนี้ได้นำเสนอวิธีการเจาะระบบผ่านเว็บในปัจจุบัน โดยทำการสร้างเว็บที่ให้ความรู้เกี่ยวกับวิธีการเจาะเว็บ โดยจะรวบรวมวิธีการเจาะระบบเว็บแบบต่างๆที่สำคัญและเป็นที่ยอมรับโดยจะบอกถึงวิธีการทดสอบการเจาะระบบในแต่ละวิธีว่าทำได้อย่างไร สามารถที่จะทำการทดสอบและทำการป้องกันได้ โดยมีหน้าเพจสำหรับการทดสอบและป้องกันในหัวข้อต่างๆ ดังนี้ SQL Injection, Hidden Manipulation, Java Injection, Cross Site Script (XSS), Query Poisoning, Session Hijacking, Parameter Tempering และ Application Buffer Overflows

1.4 วิธีการดำเนินการ

1. ศึกษาเกี่ยวกับโครงสร้างเว็บไซต์
2. ศึกษาเกี่ยวกับ Web Server, Database Server, Web Language
3. ศึกษาเกี่ยวกับ HTTP Protocol ,URL Encoding
4. ศึกษาเกี่ยวกับวิธีการเจาะระบบผ่านเว็บตามวิธีต่างๆ
5. วิเคราะห์ และออกแบบระบบ
6. สร้างเว็บไซต์ที่ให้ความรู้และในส่วน Sandbox ที่ใช้ในการทำการทดสอบและการป้องกันในแต่ละวิธี
7. ทำการปรับปรุงแก้ไขและทำการตรวจสอบให้ตรงตามวัตถุประสงค์ของโครงการ

1.5 ประโยชน์ที่คาดว่าจะได้รับ

1. มีความรู้ความเข้าใจเกี่ยวกับเทคนิคการเจาะระบบผ่านเว็บ
2. มีความรู้ความเข้าใจเกี่ยวกับการป้องกันการเจาะระบบเว็บ
3. สามารถสร้างเว็บไซต์ที่ให้ความรู้เกี่ยวกับการเจาะระบบและการป้องกันได้
4. สามารถสร้างชุดทดสอบการเจาะระบบและการป้องกันผ่านเว็บได้

1.6 ส่วนประกอบของปฏิญานิพนธ์

ปฏิญานิพนธ์ฉบับนี้ได้แบ่งเนื้อหาออกเป็น 7 บทด้วยกันคือ

บทที่ 1 กล่าวถึงความสำคัญและที่มาของโครงการ วัตถุประสงค์ของโครงการ ขอบเขตของโครงการ วิธีการดำเนินการ ประโยชน์ที่คาดว่าจะได้รับ และส่วนประกอบของปฏิญานิพนธ์

บทที่ 2 กล่าวถึงทฤษฎีพื้นฐานที่ใช้ในโครงงาน ซึ่งประกอบด้วยทฤษฎีดังนี้ คือ สถาปัตยกรรมของเว็บ, HTTP Protocol, Web Server, Database Server, Web Language, Uniform Resource Locator (URL)

บทที่ 3 ทฤษฎีการเจาะระบบผ่านเว็บ ซึ่งประกอบด้วยวิธีดังนี้ SQL Injection, Hidden Manipulation, Java Injection, Cross Site Script (XSS), Query Poisoning, Session Hijacking, Parameter Tempering และ Application Buffer Overflows

บทที่ 4 การออกแบบและพัฒนาโครงงาน โดยเริ่มตั้งแต่การศึกษาหาข้อมูลในแต่ละวิธีของเทคนิคการเจาะระบบผ่านเว็บและทำการจำลองระบบขึ้นมา

บทที่ 5 การทดลองและผลการทดลอง จะเป็นในส่วนของการทดลองและการป้องกันในแต่ละเทคนิคการเจาะระบบผ่านเว็บ

บทที่ 6 เป็นเครื่องมือช่วยเหลือในการหาช่องโหว่ของระบบ ซึ่งประกอบด้วยโปรแกรม Netcat, Whisker, Brutus, Achilles, Cookie Pal, Teleport Pro

บทที่ 7 เป็นบทวิจารณ์และสรุป ซึ่งกล่าวถึงบทสรุปของโครงงาน วิจารณ์สิ่งที่ได้รับจากโครงงาน และข้อเสนอแนะสำหรับเป็นแนวทางในการพัฒนาต่อ